

Web Application Report

This report includes important security information about your web application.

安全报告

该报告由 HCL AppScan Standard 创建 10.9.0
扫描开始时间: 2026/3/3 上午11:08:59

目录

介绍

- 常规信息
- 登陆设置

摘要

- 问题类型
- 有漏洞的 URL
- 修订建议
- 安全风险
- 原因
- WASC 威胁分类

按问题类型分组的问题

- 易受攻击的组件 ²
- “Content-Security-Policy”头缺失 ¹
- “X-Content-Type-Options”头缺失或不安全 ¹
- 在应用程序中发现不必要的 Http 响应头 ¹
- 检测到隐藏目录 ¹

修复方法

- 易受攻击的组件
- “Content-Security-Policy”头缺失
- “X-Content-Type-Options”头缺失或不安全
- 在应用程序中发现不必要的 Http 响应头
- 检测到隐藏目录

应用程序数据

- cookie
- JavaScript
- 参数
- 注释
- 已访问的 URL
- 失败的请求

- 已过滤的 URL
- 组件

介绍

该报告包含由 HCL AppScan Standard 执行的 Web 应用程序安全性扫描的结果。

高严重性问题： 2
低严重性问题： 4
报告中包含的严重性问题总数： 6
扫描中发现的严重性问题总数： 10

常规信息

扫描文件名称： 智慧统战“鹏小友”数字人系统-26-3-3
扫描开始时间： 2026/3/3 上午11:08:59
测试策略： Default
CVSS 版本： 3.1
测试优化级别： 快

主机 10.76.44.110
端口 80
操作系统： 未知
Web 服务器： 未知
应用程序服务器： 任何

登陆设置

登陆方法： 无

摘要

问题类型 5

TOC

问题类型		问题的数量	
高	易受攻击的组件	2	
低	"Content-Security-Policy"头缺失	1	
低	"X-Content-Type-Options"头缺失或不安全	1	
低	在应用程序中发现不必要的 Http 响应头	1	
低	检测到隐藏目录	1	

有漏洞的 URL 2

TOC

URL		问题的数量	
高	http://10.76.44.110/zh.json	3	
低	http://10.76.44.110/	3	

修订建议 5

TOC

修复任务		问题的数量	
高	将组件升级到最新稳定版本	2	
低	对禁止的资源发布"404 - Not Found"响应状态代码，或者将其完全除去	1	
低	将服务器配置为使用值为"nosniff"的"X-Content-Type-Options"头	1	
低	将服务器配置为使用安全策略的"Content-Security-Policy"头	1	
低	请勿允许敏感信息泄漏。	1	

安全风险 4

TOC

风险		问题的数量	
高	攻击者可能会使用 Web 服务器攻击其他站点，这将增加他（或她）的匿名性	2	
低	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置	3	
低	可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息	2	
低	可能会检索有关站点文件系统结构的信息，这可能会帮助攻击者映射此 Web 站点	1	

原因 5

TOC

原因		问题的数量
高	未安装第三方产品的最新补丁或最新修补程序	2
低	Web 应用程序编程或配置不安全	3
低	Web 服务器或应用程序服务器是以不安全的方式配置的	1

WASC 威胁分类

TOC

威胁		问题的数量
	功能滥用	2
	信息泄露	4

按问题类型分组的问题

易受攻击的组件	
严重性:	高
CVSS 分数:	7.1
CVSS 向量:	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A/H/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
CVE	CVE-2022-41742
URL:	http://10.76.44.110/zh.json
实体:	Nginx 1.21.5 (Component)
风险:	攻击者可能会使用 Web 服务器攻击其他站点，这将增加他（或她）的匿名性
原因:	未安装第三方产品的最新补丁或最新修补程序
固定值:	将组件升级到最新稳定版本

差异:

推理: AppScan 发现易受攻击的组件

测试请求和响应:

```
GET /zh.json HTTP/1.1
Host: 10.76.44.110
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/137.0.0.0 Safari/537.36
Accept: application/json, text/plain, */*
Referer: http://10.76.44.110/dialogue
Accept-Language: en-US
Connection: keep-alive
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.21.5
Date: Tue, 03 Mar 2026 03:11:21 GMT
Content-Type: application/json
Content-Length: 2026
Connection: keep-alive
Last-Modified: Wed, 03 Dec 2025 03:11:36 GMT
Vary: Accept-Encoding
ETag: "692faa68-7ea"
Accept-Ranges: bytes

{
  "dialogue": {
    "creation": "快来与统战部的AI智能体聊天吧！",
    "btn": "立即开始",
    "placeholder": "输入聊天内容",
    "newTip": "新聊天",
    "speakTip": "点击说话",
    "sendTip": "发送",
```

```

"voiceTip": "文本未识别",

"notReply": "网络异常, 请重新提问",

"await": "正在输入...",

"crash": "由于您超过1分钟没有任何操作, 此聊天已关闭。如果你打算继续 对话, 只需点击“开始新的聊天”, 重新开始我们的对话",

"crashBtn": "开始新的聊天",

"recordLimit": "发送语音不能超过一分钟",

"wordLimit": "超过字数限制: 500字。",

"tips1": "恭喜你已获得",

"tips2": "10分钟",

"tips3": "免费体验时长, 仅在当天内有效",

"tips4": "您当天的免费时长还剩余 ",

"tips5": "仅在当天内有效",

"break": "终止生成",

"timeTitle": "对话时长包剩余时长不足",

"timeEnd": "对话时长已用完",

"timeInfo1": "您当前的对话时长包剩余时长仅: ",

"timeInfo2": "如需续费时长, 请扫码联系客服经理",

"timeInfo3": "您当天的免费体验时长已用完, 可开通定制会员",

"timeInfo4": "享受定制数字人和更多对话时长包权益!",

"timeInfo5": "您当前的对话时长包剩余时长: ",

"timeInfo6": "您的对话时长包已用完, 请联系您的客户经理进行对话时长续费, 享受定制数字人和更多对话时长包权益!",

"minute": "分钟",

"second": "秒",

"breakMsg": "已终止当前答案的生成, 您可重新发起新的聊天内容",

"qrcode": "扫码咨询客户经理",

"reminder": "温馨提示",

"tips": "分享人当天的免费体验时长已用完, 建议告知分享人开通定制会员, 享受定制数字人和更多对话时长包权益!",

"remaining": "剩余时长:"

},

"lineup": {

"hint": "抱歉, 当前使用的人数较多, 请在几分钟后再尝试"

}

}

```


易受攻击的组件	
严重性：	高
CVSS 分数：	7.0
CVSS 向量：	AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
CVE	CVE-2022-41741
URL:	http://10.76.44.110/zh.json
实体：	Nginx 1.21.5 (Component)
风险：	攻击者可能会使用 Web 服务器攻击其他站点，这将增加他（或她）的匿名性
原因：	未安装第三方产品的最新补丁或最新修补程序
固定值：	将组件升级到最新稳定版本

差异：

推理： AppScan 发现易受攻击的组件

测试请求和响应：

```
GET /zh.json HTTP/1.1
Host: 10.76.44.110
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/137.0.0.0 Safari/537.36
Accept: application/json, text/plain, */*
Referer: http://10.76.44.110/dialogue
Accept-Language: en-US
Connection: keep-alive
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.21.5
Date: Tue, 03 Mar 2026 03:11:21 GMT
Content-Type: application/json
Content-Length: 2026
Connection: keep-alive
Last-Modified: Wed, 03 Dec 2025 03:11:36 GMT
Vary: Accept-Encoding
ETag: "692faa68-7ea"
Accept-Ranges: bytes

{
  "dialogue": {
    "creation": "快来与统战部的AI智能体聊天吧！",
    "btn": "立即开始",
    "placeholder": "输入聊天内容",
    "newTip": "新聊天",
    "speakTip": "点击说话",
    "sendTip": "发送",
    "voiceTip": "文本未识别",
    "notReply": "网络异常，请重新提问",
    "await": "正在输入...",
    "crash": "由于您超过1分钟没有任何操作，此聊天已关闭。如果你打算继续 对话，只需点击“开始新的聊天”，重新开始我们的对话",
    "crashBtn": "开始新的聊天",
    "recordLimit": "发送语音不能超过一分钟",
    "wordLimit": "超过字数限制：500字。",
    "tips1": "恭喜你已获得",
    "tips2": "10分钟",
    "tips3": "免费体验时长，仅在当天内有效",
    "tips4": "您当天的免费时长还剩余 ",
    "tips5": "仅在当天内有效",
    "break": "终止生成",
    "timeTitle": "对话时长包剩余时长不足",
```

```
"timeEnd": "对话时长已用完",  
  
"timeInfo1": "您当前的对话时长包剩余时长仅: ",  
  
"timeInfo2": "如需续费时长, 请扫码联系客户经理",  
  
"timeInfo3": "您当天的免费体验时长已用完, 可开通定制会员",  
  
"timeInfo4": "享受定制数字人和更多对话时长包权益!",  
  
"timeInfo5": "您当前的对话时长包剩余时长: ",  
  
"timeInfo6": "您的对话时长包已用完, 请联系您的客户经理进行对话时长续费, 享受定制数字人和更多对话时长包权益!",  
  
"minute": "分钟",  
  
"second": "秒",  
  
"breakMsg": "已终止当前答案的生成, 您可重新发起新的聊天内容",  
  
"qrcode": "扫码咨询客户经理",  
  
"reminder": "温馨提示",  
  
"tips": "分享人当天的免费体验时长已用完, 建议告知分享人开通定制会员, 享受定制数字人和更多对话时长包权益!",  
  
"remaining": "剩余时长:"  
  
  },  
  
  "lineup": {  
  
    "hint": "抱歉, 当前使用的人数较多, 请在几分钟后再尝试"  
  
  }  
  
}
```

问题 1 / 1

TOC

“Content-Security-Policy”头缺失

严重性： 低

CVSS 分数： 3.7

CVSS 向量： AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X

URL: <http://10.76.44.110/>

实体： 10.76.44.110 (Page)

风险： 可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息

原因： Web 应用程序编程或配置不安全

固定值： 将服务器配置为使用安全策略的“Content-Security-Policy”头

差异：

推理： AppScan 检测到 Content-Security-Policy 响应头缺失或具有不安全策略，这可能会更大程度地暴露于各种跨站点注入攻击之下

测试请求和响应：

```
GET /assets/index-y2wN8vvU.js HTTP/1.1
Host: 10.76.44.110
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/137.0.0.0 Safari/537.36
Origin: http://10.76.44.110
Accept: */*
Referer: http://10.76.44.110/
Accept-Language: en-US
Connection: keep-alive
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.21.5
Date: Tue, 03 Mar 2026 03:09:26 GMT
Content-Type: application/javascript
Content-Length: 157316
Connection: keep-alive
Last-Modified: Wed, 03 Dec 2025 03:11:44 GMT
ETag: "692faa70-26684"
Expires: Wed, 03 Mar 2027 03:08:47 GMT
Cache-Control: max-age=31536000
Cache-Control: public, immutable
Accept-Ranges: bytes

function __vite_mapDeps(indexes) {
  if (!__vite_mapDeps.viteFileDeps) {
    __vite_mapDeps.viteFileDeps = ["/AppWebview-CzrU32Z7.js", "/Initialization-Cj0lsv3y.js", "/Initialization-ChnJJWiD.css", "/AppWebview-GBttMozH.css", "/Dialogue-BrWavag0.js", "/Dialogue-IsWnEp11.css"]
  }
  return indexes.map((i) => __vite_mapDeps.viteFileDeps[i])
}

(function() {const t=document.createElement("link").relList;if(t&&t.supports&&t.supports("modulepreload"))return;for(const l of document.querySelectorAll('link[rel="modulepreload"]'))r(l);new MutationObserver(l=>{for(const s of l)if(s.type==="childList")for(const o of s.addedNodes)o.tagName==="LINK"&&o.rel==="modulepreload"&&r(o)}).observe(document,{childList:!0,subtree:!0});function n(l){const s={};return l.integrity&&(s.integrity=l.integrity),l.referrerPolicy&&(s.referrerPolicy=l.referrerPolicy),l.crossOrigin==="use-credentials"?s.credentials="include":l.crossOrigin==="anonymous"?s.credentials="omit":s.credentials="same-origin",s}function r(l){if(l.ep)return;l.ep=!0;const s=n(l);fetch(l.href,s)}()};/**
 * @vue/shared v3.4.21
 * (c) 2018-present Yuxi (Evan) You and Vue contributors
 * @license MIT
 */function is(e,t){const n=new Set(e.split(","));return t?r=>n.has(r.toLowerCase()):r=>n.has(r)}const _e={},m=[],Ye=()=>{};Ya=
()=>!1,pr=>e.charCodeAt(0)===111&&e.charCodeAt(1)===110&&(e.charCodeAt(2)>122||e.charCodeAt(2)<97),Ns=>e.startsWith("onUpdate:"),Se=Object.assign,Os=(e,t)>=>{const
n=e.indexOf(t);n>=1&&e.splice(n,1)},Xa=Object.prototype.hasOwnProperty,ae=(e,t)>=>Xa.call(e,t),J=Array.isArray,sn=>gr(e)=="[object Map]",Zo=>gr(e)=="[object
Set]",ne=>typeof e=="function",ve=>typeof e=="string",_n=>typeof e=="symbol",me=>e!=null&&typeof e=="object",zo=>
(me(e)||ne(e))&&ne(e.then)&&ne(e.catch),ei=Object.prototype.toString,gr=>ei.call(e),qa=>gr(e).slice(8,-1),ti=>gr(e)=="[object
Object]",Ss=>ve(e)&&e!="NaN"&&e[0]!="-",
"%&""+parseInt(e,10)===Er,Is=Is("key,ref,ref_for,ref_key,onNodeBeforeMount,onNodeMounted,onNodeBeforeUpdate,onNodeUpdated,onNodeBeforeUnmount,onNodeUnmounted"),Er=>
{const t=Object.create(null);return n=>t[n]||t[n]=e(n)},Ja=>/-([a-z])/g,ft=Er(e=>e.replace(Ja,(t,n)>=>n.toUpperCase():"")),Qa=>/B([A-Z])/g,qt=Er(e=>e.replace(Qa,"-
```

低

“X-Content-Type-Options”头缺失或不安全 1

TOC

问题 1 / 1

差异：

推理： AppScan 检测到“X-Content-Type-Options”响应头缺失或具有不安全值，这可能会更大程度地暴露于偷渡式下载攻击之下

测试请求和响应：

```
GET /zh.json HTTP/1.1
Host: 10.76.44.110
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/137.0.0.0 Safari/537.36
Accept: application/json, text/plain, */*
Referer: http://10.76.44.110/dialogue
Accept-Language: en-US
Connection: keep-alive
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.21.5
Date: Tue, 03 Mar 2026 03:11:21 GMT
Content-Type: application/json
Content-Length: 2026
Connection: keep-alive
Last-Modified: Wed, 03 Dec 2025 03:11:36 GMT
Vary: Accept-Encoding
ETag: "692faa68-7ea"
Accept-Ranges: bytes

{
  "dialogue": {
    "creation": "快来与统战部的AI智能体聊天吧！",
    "btn": "立即开始",
```

```

"placeholder": "输入聊天内容",

"newTip": "新聊天",

"speakTip": "点击说话",

"sendTip": "发送",

"voiceTip": "文本未识别",

"notReply": "网络异常, 请重新提问",

"await": "正在输入...",

"crash": "由于您超过1分钟没有任何操作, 此聊天已关闭。如果你打算继续 对话, 只需点击“开始新的聊天”, 重新开始我们的对话",

"crashBtn": "开始新的聊天",

"recordLimit": "发送语音不能超过一分钟",

"wordLimit": "超过字数限制: 500字。",

"tips1": "恭喜你已获得",

"tips2": "10分钟",

"tips3": "免费体验时长, 仅在当天内有效",

"tips4": "您当天的免费时长还剩余 ",

"tips5": "仅在当天内有效",

"break": "终止生成",

"timeTitle": "对话时长包剩余时长不足",

"timeEnd": "对话时长已用完",

"timeInfo1": "您当前的对话时长包剩余时长仅: ",

"timeInfo2": "如需续费时长, 请扫码联系客服经理",

"timeInfo3": "您当天的免费体验时长已用完, 可开通定制会员",

"timeInfo4": "享受定制数字人和更多对话时长包权益!",

"timeInfo5": "您当前的对话时长包剩余时长: ",

"timeInfo6": "您的对话时长包已用完, 请联系您的客户经理进行对话时长续费, 享受定制数字人和更多对话时长包权益!",

"minute": "分钟",

"second": "秒",

"breakMsg": "已终止当前答案的生成, 您可重新发起新的聊天内容",

"qrcode": "扫码咨询客户经理",

"reminder": "温馨提示",

"tips": "分享人当天的免费体验时长已用完, 建议告知分享人开通定制会员, 享受定制数字人和更多对话时长包权益!",

"remaining": "剩余时长:"

},

"lineup": {

"hint": "抱歉, 当前使用的人数较多, 请在几分钟后重试"

}

}

```

低

在应用程序中发现不必要的 Http 响应头 ①

TOC

问题 1 / 1

TOC

在应用程序中发现不必要的 Http 响应头	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	http://10.76.44.110/zh.json
实体：	10.76.44.110 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	Web 应用程序编程或配置不安全
固定值：	请勿允许敏感信息泄漏。

差异：

推理： 响应包含不必要的头，这可能会帮助攻击者计划进一步攻击。

测试请求和响应：

```
GET /zh.json HTTP/1.1
Host: 10.76.44.110
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/137.0.0.0 Safari/537.36
Accept: application/json, text/plain, */*
Referer: http://10.76.44.110/dialogue
Accept-Language: en-US
Connection: keep-alive
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.21.5
Date: Tue, 03 Mar 2026 03:11:21 GMT
Content-Type: application/json
Content-Length: 2026
Connection: keep-alive
Last-Modified: Wed, 03 Dec 2025 03:11:36 GMT
Vary: Accept-Encoding
ETag: "692faa68-7ea"
Accept-Ranges: bytes

{
  "dialogue": {
    "creation": "快来与统战部的AI智能体聊天吧！",
    "btn": "立即开始",
    "placeholder": "输入聊天内容",
    "newTip": "新聊天",
    "speakTip": "点击说话",
    "sendTip": "发送",
    "voiceTip": "文本未识别",
    "notReply": "网络异常，请重新提问",
    "await": "正在输入...",
    "crash": "由于您超过1分钟没有任何操作，此聊天已关闭。如果你打算继续 对话，只需点击“开始新的聊天”，重新开始我们的对话",
    "crashBtn": "开始新的聊天",
    "recordLimit": "发送语音不能超过一分钟",
    "wordLimit": "超过字数限制：500字。",
    "tips1": "恭喜你已获得",
    "tips2": "10分钟",
    "tips3": "免费体验时长，仅在当天内有效",
    "tips4": "您当天的免费时长还剩余 ",
    "tips5": "仅在当天内有效",
    "break": "终止生成",
    "timeTitle": "对话时长包剩余时长不足",
    "timeEnd": "对话时长已用完",
```

```
"timeInfo1": "您当前的对话时长包剩余时长仅：",
"timeInfo2": "如需续费时长，请扫码联系客服经理",
"timeInfo3": "您当天的免费体验时长已用完,可开通定制会员",
"timeInfo4": "享受定制数字人和更多对话时长权益!",
"timeInfo5": "您当前的对话时长包剩余时长：",
"timeInfo6": "您的对话时长包已用完，请联系您的客户经理进行对话时长续费，享受定制数字人和更多对话时长权益！",
"minute": "分钟",
"second": "秒",
"breakMsg": "已终止当前答案的生成，您可重新发起新的聊天内容",
"qrcode": "扫码咨询客户经理",
"reminder": "温馨提示",
"tips": "分享人当天的免费体验时长已用完，建议告知分享人开通定制会员，享受定制数字人和更多对话时长权益！",
"remaining": "剩余时长:"
},
"lineup": {
"hint": "抱歉，当前使用的人数较多，请在几分钟后再尝试"
}
}
```

问题 1 / 1

TOC

检测到隐藏目录	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	http://10.76.44.110/
实体：	assets/ (Page)
风险：	可能会检索有关站点文件系统结构的信息，这可能会帮助攻击者映射此 Web 站点
原因：	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值：	对禁止的资源发布“404 - Not Found”响应状态代码，或者将其完全除去

差异： 路径 从以下位置进行控制： /zh.json 至： /assets/

推理： 测试尝试检测服务器上的隐藏目录/文件。响应状态为 200 OK 或 403 Forbidden。状态 200 表示测试成功检索了所请求目录/文件的内容。状态 403 表明它确实存在，尽管不允许访问。

测试请求和响应：

```
GET /assets/ HTTP/1.1
Host: 10.76.44.110
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/137.0.0.0 Safari/537.36
Accept: application/json, text/plain, */*
Referer: http://10.76.44.110/dialogue
Accept-Language: en-US
Connection: keep-alive
Content-Length: 0

HTTP/1.1 403 Forbidden
```

Server: nginx/1.21.5
Date: Tue, 03 Mar 2026 03:10:20 GMT
Content-Type: text/html
Content-Length: 555
Connection: keep-alive

```
<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx/1.21.5</center>
</body>
</html>
<!-- a padding to disable MSIE and Chrome friendly error page -->
<!-- a padding to disable MSIE and Chrome friendly error page -->
<!-- a padding to disable MSIE and Chrome friendly error page -->
<!-- a padding to disable MSIE and Chrome friendly error page -->
<!-- a padding to disable MSIE and Chrome friendly error page -->
<!-- a padding to disable MSIE and Chrome friendly error page -->
```


修复方法

易受攻击的组件

TOC

原因:
测试的应用程序中使用了易受攻击的组件。

风险:
易受攻击的组件可能会给应用程序带来各种形式的漏洞

修订建议:
常规

升级到组件的最新版本。如果该组件已到达其生命周期结束（EOL），请用最近支持的替代品替换该组件。我们强烈建议联系该产品的供应商，看看是否最近有补丁或修复程序可用。

CWE:
1395

外部引用:
[CERT 协调中心](#)
[常见漏洞和暴露 \(CVE\)](#)

“Content-Security-Policy”头缺失

TOC

原因:
Web 应用程序编程或配置不安全

风险:
可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
CSP 值缺失或不当会导致 Web 应用程序容易受到 XSS、点击劫持等的攻击。
“Content-Security-Policy”头旨在修改浏览器呈现页面的方式，从而防止各种跨站点注入，包括跨站点脚本编制。以不会妨碍 Web 站点正常运行的方式正确设置头值非常重要。例如，如果头设置为阻止执行内联 JavaScript，则 Web 站点不得在其页面中使用内联 JavaScript。
要防止跨站点脚本编制攻击、跨框架脚本编制攻击和点击劫持，请务必使用正确的值设置以下策略：
“default-src”和“frame-ancestors”策略*或**“script-src”、“object-src”和“frame-ancestors”策略
对于“default-src”、“script-src”和“object-src”，应避免使用不安全的值，例如“*”、“data:”、“unsafe-inline”或“unsafe-eval”。
对于“frame-ancestors”，应避免使用不安全的值，例如“*”或“data:”。
此外，对于“script-src”和“default-src”（“script-src”的备用指令），“self”被认为是不安全的，应该避免使用。
请参考以下链接以获取更多信息。
请注意，“Content-Security-Policy”包括四个不同的测试。常规测试用于验证是否正在使用“Content-Security-Policy”标头，另外三个测试用于检查“Frame-Ancestors”、“Object-Src”和“Script-Src”是否配置正确。

受影响产品:
此问题可能影响不同类型的产品

修订建议：

常规

配置服务器以发送“Content-Security-Policy”头。
建议将 Content-Security-Policy 头配置为其指令的安全值，如下所示：
对于“default-src”和“script-src”，需要使用诸如“none”或 <https://any.example.com> 之类的安全值。
对于“frame-ancestors”和“object-src”，需要使用诸如“self”、“none”或 <https://any.example.com> 之类的安全值。
在任何情况下都不得使用“unsafe-inline”和“unsafe-eval”。使用 nonce/hash 只会被视为短期解决方法。
关于 Apache，请参阅：
http://httpd.apache.org/docs/2.2/mod/mod_headers.html
关于 IIS，请参阅：
<https://technet.microsoft.com/pl-pl/library/cc753133%28v=ws.10%29.aspx>
关于 nginx，请参阅：
http://nginx.org/en/docs/http/nginx_headers_module.html

CWE:

1032
79
693
830
1021

外部引用：

[一些安全头的列表](#)
[内容安全策略简介](#)
[MDN Web 文档 - 内容安全策略](#)

“X-Content-Type-Options”头缺失或不安全

TOC

原因：

Web 应用程序编程或配置不安全

风险：

可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息。
“X-Content-Type-Options”头（具有“nosniff”值）防止 IE 和 Chrome 忽略响应的内容类型。
此操作可能防止不可信内容（例如，用户上传内容）在用户浏览器上执行（例如，在恶意命名之后）。

受影响产品：

此问题可能影响不同类型的产品

修订建议：

常规

将服务器配置为针对所有外发请求发送具有值“nosniff”的“X-Content-Type-Options”头。
关于 Apache，请参阅：
http://httpd.apache.org/docs/2.2/mod/mod_headers.html
关于 IIS，请参阅：
<https://technet.microsoft.com/pl-pl/library/cc753133%28v=ws.10%29.aspx>
关于 nginx，请参阅：
http://nginx.org/en/docs/http/nginx_headers_module.html

CWE:

200
693

外部引用：
有用 HTTP 头列表
减少 MIME 类型安全风险

在应用程序中发现不必要的 Http 响应头

TOC

原因：
不安全的 Web 应用程序编程或配置

风险：
可能会收集有关 Web 服务器类型、版本、操作系统等的敏感信息。
AppScan 检测到不必要的 Http 响应头。
出于安全和隐私方面的原因，“Server”、“X-Powered-By”、“X-AspNetMvc-Version”和“X-AspNet-Version”等 Http 响应头不应出现在网页中。
“Server”头是每当服务器向客户机发送响应时通常会缺省添加的头。
“X-Powered-By”头是每当服务器向客户机发送响应时可能会缺省添加的头。
这些添加的头可能会泄露有关内部服务器软件版本和类型的敏感信息，从而使攻击者能够对其进行指纹识别并有针对性地利用漏洞进行攻击。此外，当一个新的漏洞为公众所知时，服务器很可能会受到利用该漏洞发起的攻击。

受影响产品：
此问题可能会影响不同类型的产品。

修订建议：

常规

配置服务器以除去向所有外发请求发送的缺省“Server”头。
关于 IIS，请参阅：
<https://techcommunity.microsoft.com/t5/iis-support-blog/remove-unwanted-http-response-headers/ba-p/369710>
关于 nginx，请参阅：
<https://www.getpagespeed.com/server-setup/nginx/how-to-remove-the-server-header-in-nginx>
关于 Weblogic，请参阅：
https://docs.oracle.com/cd/E13222_01/wls/docs81/adminguide/web_server.html
关于 Apache，请参阅：
<https://techglimpse.com/set-modify-response-headers-http-tip/>

CWE:
200
668
497

外部引用：
指纹
防止信息泄露

检测到隐藏目录

TOC

原因：
Web 服务器或应用程序服务器是以不安全的方式配置的

风险：
可能会检索有关站点文件系统结构的信息，这可能会帮助攻击者映射此 Web 站点
Web 应用程序显现了站点中的目录。虽然目录并没有列出其内容，但此信息可以帮助攻击者发展对站点进一步的攻击。例如，知道目录名称之后，攻击者便可以猜测它的内容类型，也许还能猜出其中的文件名或子目录，并尝试访问它们。
内容的敏感度越高，此问题也可能越严重。

受影响产品:

该问题可能会影响各种类型的产品。

修订建议:

常规

如果不需要禁止的资源，请将其从站点中除去。
可能的话，请发出改用“404 — 找不到”响应状态代码，而不是“403 — 禁止”。这项更改会将站点的目录模糊化，可以防止泄漏站点结构。

CWE:

200
497

应用程序数据

已访问的 URL 13

TOC

URL
http://10.76.44.110/
http://10.76.44.110/assets/index-y2wN8wU.js
http://10.76.44.110/assets/Dialogue-BnWavag0.js
http://10.76.44.110/assets/Initialization-CjO1sv3y.js
http://10.76.44.110/zh.json
http://10.76.44.110/assets/OneHandedIntroduction-Bpm7m6u7.json
http://10.76.44.110/assets/IntroductionToHands-DdUCrezP.json
http://10.76.44.110/assets/Proud-CyH-O1_i.json
http://10.76.44.110/assets/Like-C6B-pj_A.json
http://10.76.44.110/assets/Think-okU8t7ra.json
http://10.76.44.110/assets/Greet-BvFrOIHN.json
http://10.76.44.110/assets/Speak-BQeL-cOM.json
http://10.76.44.110/assets/NoSpeak-D0MQLJoK.json

参数 0

TOC

名称	值	URL	类型
----	---	-----	----

失败的请求 1

TOC

URL	原因
http://10.76.44.110/assets/	响应状态“403” — 禁止

已过滤的 URL 2

TOC

URL	原因
http://10.76.44.110/assets/logo-D4Y1DV54.ico	文件扩展名
http://10.76.44.110/assets/index-BuJMuS2k.css	文件扩展名

注释 1

TOC


```
i=update:$($o)` ,n=onUpdate:$($o)` ,a=[1],u={ [o]:Tw, [n]:Ew); return(useModelToggle: ({indicator:f, toggleReason:v, shouldHideWhenRouteChanges:w, shouldProceed:b, onShow:g, onHide:E})=>(const A=Kr(), (emit:C)=A, R=A.props, I=J(( )=>Dr(R[n])), U=J(( )=>R[o]==null), k=H=>{f.value!==0&&(f.value=10,v&&(v.value=H), Dr(g)&&g(H))), $=H=>{f.value!==1&&(f.value=11,v&&(v.value=H), Dr(E)&&E(H))), m=H=>{if(R.disabled===0||Dr(b)&&b(! ) )return;const Y=I.value&&un;Y&&C(i,! ), (U.value||!Y)&&k(H)}, x=H=>{if(R.disabled===0||!un)return;const Y=I.value&&un;Y&&C(i,! ), (U.value||!Y)&&g(H)}, q=H=>{ua&&(R.disabled&&H?I.values&&C(i,! ):f.value!==H&&(H?k():$()))}, V=()=>{f.value?x():m() };return Pe(( )=>R[o],g), w&&A.appContext.config.globalProperties.$route!==void 0&&Pe(( )=>((...A.proxy.$route)), ()=>{w.values&&f.values&&x()}), ...
```

http://10.76.44.110/assets/Initialization-CJO1sv3yjs

```
var $=Object.defineProperty;var Ns=(e,r,o)=>r in e?$s(e,r,{enumerable:!0,configurable:!0,writable:!0,value:o}):e[r]=o;var _e=(e,r,o)=>(Ns(e,typeof r!="symbol"?r+"":r,o),o);import(c as computed,r as ref,a$ as getCurrentScope,M as onScopeDispose,a as unref,g as getCurrentInstance,o as onMounted,H as nextTick,$3,_ as readonly,w as watch,d as isString,$5,a9 as camelize,e as defineComponent,f as openBlock,h as createElementBlock,m as createBaseNode,U as isObject,$4,aa as hasOwn,ab as warn,N as NOOP,Y as isArray,$4,i as isVNode,C as inject,K as isRef,p as provide,y as renderSlot,S as mergeProps,t as createVNode,k as withCtx,l as withDirectives,n as normalizeClass,z as normalizeStyle,B as toDisplayString,v as vShow,T as Transition,ac as shallowReactive,j as createBlock,x as createCommentVNode,R as resolveDynamicComponent,F as Fragment,q as withModifiers,I as isFunction,$5,ad as render,ae as defineStore,G as useI18n)from"./index-y2wNvU.js";var a$2;const isClient=typeof window<"u",isFunction$4=e=>typeof e=="function",isString$4=e=>typeof e=="string",noop$3=()=>{},isIOS=isClient&&(( a$2>window===null?void 0>window.navigator)===null?void 0: a$2.userAgent)&&/IP(ad|hone|od)/.test(window.navigator.userAgent);function resolveUnref(e){return typeof e=="function"?e():unref(e)}function identity(e){return e}function tryOnScopeDispose(e){return getCurrentScope()? (onScopeDispose(e),!0):!1}function resolveRef(e){return typeof e=="function"?computed(e):ref(e)}function tryOnMounted(e,r=!0){getCurrentInstance()?onMounted(e):r?e():nextTick$3(e)}function useTimeoutFn(e,r,o={}){const{immediate:a=!0,o,c=ref(!1)}=o,l=null;function u(){l&&(clearTimeout(l),l=null)}function f(){c.value=!1,u()}function p(...v){u(),c.value=!0,l=setTimeout(()=>{c.value=!1,l=null,e(...v)},resolveUnref(r))}return a&&(c.value=!0,isClient&&p()),tryOnScopeDispose(f),{isPending:readonly(c),start:p,stop:f}}function unrefElement(e){var r;const o=resolveUnref(e);return(r=o===null?void 0:o.$el)!=null?r:o}const defaultWindow=isClient?window:void 0,defaultDocument=isClient?window.document:void 0;function useEventListener(...e){let r,o,a,c;if(isString$4(e[0])||Array.isArray(e[0])?(o,a,c)=e,r=defaultWindow:void 0,lr)return noop$3;Array.isArray(o)|| (o=[o],Array.isArray(a)|| (a=[a]));const l=[],u=()=>l.forEach(g=>g(),l.length=0),f=(g,E,S,k)=>(g.addEventListener(E,S,k), ()=>g.removeEventListener(E,S,k)),p=watch(()=>unrefElement(r),resolveUnref(c)), ([g,E])=>{u(),g&&l.push(...o.flatMap(S=>a.map(k=>f(g,S,k,E))))}, {immediate:!0,flush:"post"}),v=()=>{p(),u()});return tryOnScopeDispose(v),v}let _IOSWorkaround=!1;function onClickOutside(e,r,o={}){const(window=a=defaultWindow,ignore:c=[]) ,capture:l=!0,detectIframe:v=!1)=>{if(!a)return;isIOS&&! _IOSWorkaround&&( _IOSWorkaround=!0,Array.from(a.document.body.children).forEach(S=>S.addEventListener("click",noop$3)));let f=!0;const p=S=>c.some(k=>{if(typeof k=="string")return Array.from(a.document.querySelectorAll(k)).some(A=>A===S.target||S.composedPath().includes(A));(const A=unrefElement(k);return A&&(S.target===A||S.composedPath().includes(A))))},g=[useEventListener(a,"click",S=>{const k=unrefElement(e);if(! (!k||k===S.target||S.composedPath().includes(k))){if(S.detail===0&&(f=!p(S)),!f){f=!0;return}r(S)}}, {passive:!0,capture:!1}),useEventListener(a,"pointerdown",S=>{const k=unrefElement(e);k&&(f=!S.composedPath().includes(k)&&!p(S)}), {passive:!0}),u&&useEventListener(a,"blur",S=>{var k;const A=unrefElement(e);(k=A.document.activeElement)===null?void 0:k.tagName==="IFRAME"&&! (A!=null&&A.contains(a.document.activeElement))&&r(S)}]).filter(Boolean);return ()=>g.forEach(S=>S())}function useSupported(e,r=!1){const o=ref(),a=()=>o.value=!1e()};return a(),tryOnMounted(a,r,o)}const global$2=typeof globalThis<"u"?globalThis:typeof window<"u"?window:typeof global<"u"?global:typeof self<"u"?self:({},globalKey=" vueuse ssr handlers "; global$2[globalKey]=global$2[globalKey]||{});var __getOwnPropSymbols$__=Object.getOwnPropertySymbols, _hasOwnProp$__=Object.prototype.hasOwnProperty, __propIsEnum$__=Object.prototype.propertyIsEnumerable, __objRest$2=(e,r)=>{var o={};for(var a in e) _hasOwnProp$__g.call(e,a)&&r.indexOf(a)<0&&(o[a]=e[a]);if(e!=null&& __getOwnPropSymbols$__g)for(var a of __getOwnPropSymbols$__g(e))r.indexOf(a)<0&& __propIsEnum$__g.call(e,a)&&(o[a]=e[a]);return o};function useResizeObserver(e,r,o={}){const a=o,{window:c=defaultWindow}=a,l= __objRest$2(a,["window"]);let u;const f=useSupported(()=>c&&"ResizeObserver"in c),p=()=>{u&&(u.disconnect(),u=void 0)},v=watch(()=>unrefElement(e),E=>{p(),f.value&&c&&E&&(u=new ResizeObserver(r),u.observe(E,l))), {immediate:!0,flush:"post"}},g=()=>{p(),v()});return tryOnScopeDispose(g),{isSupported:f,stop:g}}var __getOwnPropSymbols$__=Object.getOwnPropertySymbols, _hasOwnProp$__=Object.prototype.hasOwnProperty, __propIsEnum$__=Object.prototype.propertyIsEnumerable, __objRest$1=(e,r)=>{var o={};for(var a in e) _hasOwnProp$__8.call(e,a)&&r.indexOf(a)<0&&(o[a]=e[a]);if(e!=null&& __getOwnPropSymbols$__8)for(var a of __getOwnProp...
```

cookie

TOC

名称	首先设置	域	安全	仅 HTTP	同一站点	JS 堆栈跟踪
值	请求的 URL		到期			

组件

TOC

名称	版本	URL
Nginx	1.21.5	http://10.76.44.110/zh.json